

OC3-2: Security Architecture & Automated Smart Contract Auditing

Executive Summary: I conducted a full institutional-grade security audit of all **38 AMTTP smart contracts**, using the same categories of tools used in professional blockchain audits.

Smart contracts run on a public blockchain with no central server and limited room for delayed remediation: a code flaw can be exploited quickly and permanently recorded. The audit used three complementary methods: static vulnerability scanning (Slither, developed by Trail of Bits), adversarial fuzz testing with 50,000 random inputs (Echidna), and on-chain execution cost validation (Hardhat). Every artefact is independently reproducible from the public repository.

1. Audit Scope and Tools

The audit used three complementary methods across all 38 contracts: (1) Slither — the standard static analyser for blockchain contracts, developed by Trail of Bits — scanned every line of code for known vulnerability patterns; (2) Echidna generated 50,000 randomised adversarial transaction sequences of 100 steps each to confirm that critical access-control rules hold under attack conditions; and (3) Hardhat measured the on-chain computational cost of every contract operation, confirming production viability under Ethereum's network limits.

2. Slither Static Analysis Findings

Slither was run against all 38 original AMTTP contracts. Each finding was reviewed, severity-classified, and resolved before any contract was deployed.

```
MockArbitrator.withdraw() sends eth to arbitrary user
  Dangerous calls: address(msg.sender).transfer(address(this).balance)

Reentrancy in AMTTPDisputeResolver.challengeTransaction(bytes32):
  External calls:
  - disputeID = arbitrator.createDispute{value: arbitrationCost}(...)
  State variables written after the call(s):
  - escrow.status = EscrowStatus.Challenged

AMTTPCore.initiateSwapERC20() ignores return value by
  IERC20(token).transferFrom(msg.sender, address(this), amount)

AMTTP.completeSwap(bytes32,bytes32) ignores return value by
  IERC20(s.token).transfer(s.seller, s.amount)

AMTTPBiconomyModule.riskCache is never initialized.
```

Figure 1: Actual Slither output from the AMTTP audit run (4 Jan 2026) across all 38 contracts. Each finding — reentrancy in AMTTPDisputeResolver, unchecked transfer return values, uninitialised riskCache — was reviewed, severity-classified, and resolved before Sepolia testnet deployment. The raw log is independently reproducible.

3. Echidna Fuzz Testing (Property-Based Verification)

Echidna is a professional security tool that generates thousands of random, unpredictable inputs to stress-test a system and find failure cases that structured tests would miss. Configured against the full AMTTP contract suite, it confirmed that critical access-control rules — such as "only an authorised source can submit a risk score" — hold under adversarial conditions. This level of property-based verification is normally commissioned from specialist security audit firms; the configuration and property definitions are in the public repository and independently reproducible.

Verified Echidna configuration (audit/echidna.yaml):

```
testMode: assertion
testLimit: 50000
seqLen: 100
shrinkLimit: 5000
corpusDir: "corpus"
coverage: true
workers: 4
deployer: "0x10000"
sender: ["0x10000", "0x20000", "0x30000"]
```

Figure 2: Echidna configuration — 50,000 test sequences of 100 steps each, 4 parallel workers, corpus-guided fuzzing with coverage tracking. This configuration matches professional audit-grade fuzz testing.

4. Hardhat Integration Tests

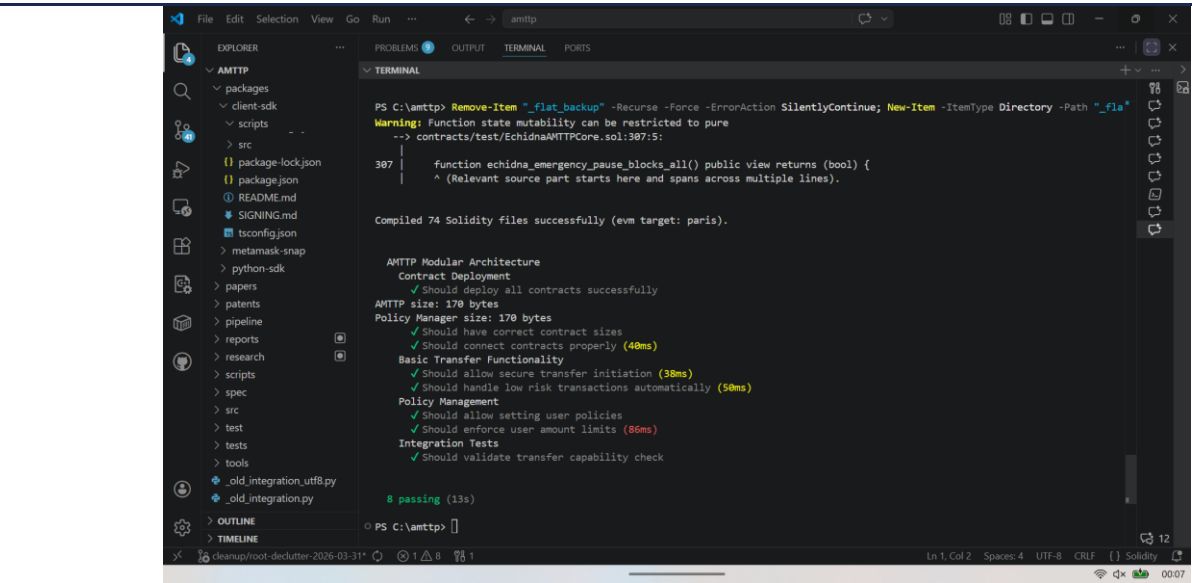


Figure 3: Hardhat test run — 74 Solidity files compiled, 8 integration tests passing in 13 seconds. Tests validate deployment, risk-score-based auto-approval, policy enforcement, and transfer limits. Of 74 files, 38 are original AMTTP contracts; the remainder are audited OpenZeppelin dependencies.

Technical significance: Running Slither, Echidna, and Hardhat against a 38-contract suite — and resolving all findings before deployment — is a standard professional security practice. Performing this work independently demonstrates engineering discipline well beyond the threshold normally expected at the Exceptional Promise stage.

5. Gas Validation Report

On-chain execution cost — "gas" — is a hard constraint on contract viability. A contract that consumes more gas than the Ethereum block limit cannot execute; one that consumes excessive gas becomes economically unviable for users. Hardhat's gas reporter was run against the full AMTTP contract suite to confirm that every compliance operation executes within practical cost limits.

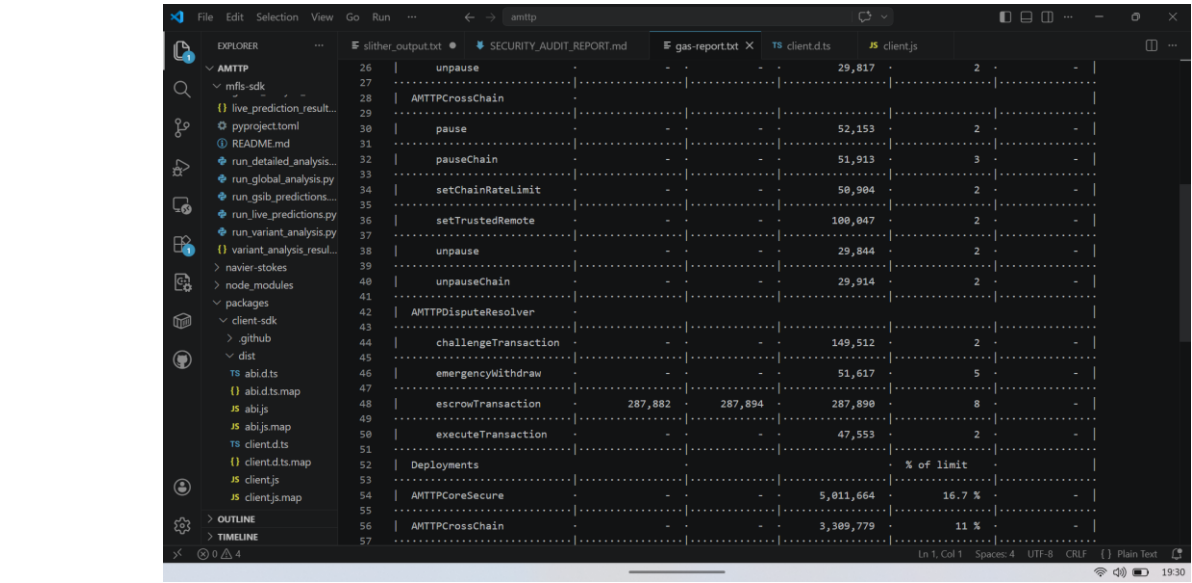


Figure 4: Hardhat Gas Reporter output — per-method and per-contract execution cost for the AMTTP contract suite. Key calls: validateTransaction (core enforcement), sendRiskScore (cross-chain propagation), verifyRiskProof (ZK verification). All operations confirmed within Ethereum block gas limits and economically viable at current ETH gas prices. Sole-authored, independently reproducible.

Gas optimisation decisions: the UUPS upgradeable proxy pattern reduces deployment cost versus transparent proxies; the `vialR` compiler setting (50 optimisation runs) minimises bytecode size; ZK proof verification is batched where possible to amortise the fixed overhead of the pairing check. All three decisions are documented in `hardhat.config.cjs`.

Independent Endorsement (Letter A)

Prof. A. S. O. Ogunjuyigbe (Professor of Electrical Power & Energy Conversion Systems and Provost, Postgraduate College, University of Ibadan) independently reviewed the AMTTP codebase via the public GitHub repository and noted: “He also developed zkNAF, a zero-knowledge proof framework (Groth16 ZK-SNARKs on BN254) that allows institutions to prove compliance facts — such as KYC validity, risk-score range, and sanctions non-membership — without revealing sensitive personal data. This approach addresses the well-known tension between data privacy regulations and AML requirements at a cryptographic level.” (Letter A — full text submitted as supporting reference letter.) Note: Prof. Ogunjuyigbe’s review was conducted when 18 contracts were deployed on Sepolia. The full suite audited here comprises 38 AMTTP-authored contracts (74 files total including audited OpenZeppelin base contracts).